SRM INSTITUTE OF SCIENCE AND TECHNOLOGY

College of Engineering and Technology | School of Computing
Department of Data Science and Business Systems

ENTERPRISE RISK MITIGATION & MANAGEMENT PLAN

Comprehensive Risk Register & 5x5 Heat Map Analysis based on Real Listed Company Disclosures
Case Organization: One97 Communications Limited (Paytm) [NSE: PAYTM | BSE: 543396]

Course: 21CSE449T – Risk Analytics | **Academic Year:** 2026–27 (ODD)
Programme: B.Tech – CSE (BDA & DS) | **Faculty:** Dr. V. Prasanna

1. Executive Summary & Corporate Risk Context

This regulatory and operational risk assessment examines **One97 Communications Limited (Paytm)**, India's pioneer digital payments and financial services ecosystem. Following the watershed supervisory action initiated by the **Reserve Bank of India (RBI)** on January 31, 2024, under Section 35A of the Banking Regulation Act, 1949, against its associate entity, Paytm Payments Bank Limited (PPBL), Paytm was thrust into an unprecedented enterprise risk crisis. The regulatory ban on deposits, credit products, prepaid wallets, and FASTag top-ups revealed compounding vulnerabilities across regulatory compliance, operational continuity, third-party dependencies, financial stability, and public brand perception.

This document operationalizes an end-to-end **Enterprise Risk Management (ERM) Framework** adhering to **ISO 31000 / COSO ERM** principles. A rigorous deep-dive of Paytm's FY 2023–24 and FY 2024–25 statutory annual filings, auditor notes, and regulatory disclosures was conducted to identify **15 mission-critical enterprise risks** spanning six structural risk domains. Each risk is evaluated quantitatively via Likelihood (1–5) and Impact (1–5) scoring, calibrated against strategic Key Risk Indicators (KRIs), and paired with multi-horizon mitigation controls.

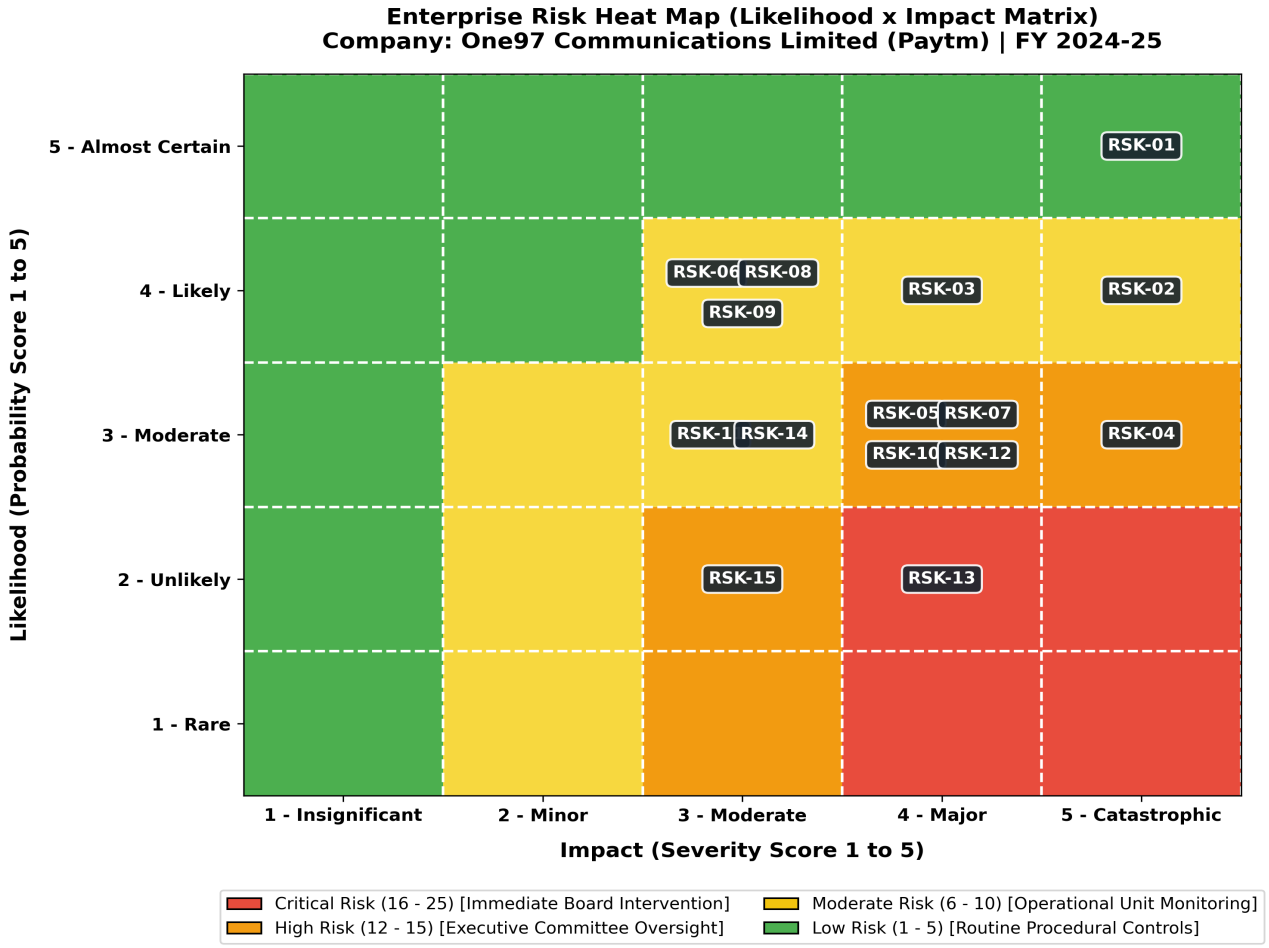
2. Enterprise Risk Governance & Scoring Methodology

The risk prioritization engine utilizes a standardized **5x5 Risk Matrix** where Risk Score = Likelihood (L) × Impact (I), yielding scores from 1 to 25:

- **Critical Risk (Red, Score 16–25):** Immediate existential or regulatory disruption. Requires Board of Directors and Risk Management Committee (RMC) intervention.
- **High Risk (Orange, Score 12–15):** Significant financial or operational harm. Demands active C-suite execution and weekly KRI monitoring.
- **Moderate Risk (Yellow, Score 6–10):** Medium-term operational exposure. Governed via functional heads and monthly audit reports.
- **Low Risk (Green, Score 1–5):** Routine operational variance managed through standard internal operating procedures (SOPs).

3. Enterprise Risk Heat Map (Likelihood x Impact Matrix)

The visual mapping below distributes all 15 identified corporate risks across the likelihood-severity coordinates, illustrating the critical concentration of regulatory, operational, and settlement exposures following the PPBL transition.



Risk Severity Distribution Summary

• **Critical Severity (Score 16–25): 3 Risks (20%)** — RSK-01 (PPBL Regulatory Action), RSK-02 (Settlement Disruption), RSK-03 (UPI TPAP Cap).
• **High Severity (Score 12–15): 7 Risks (46.7%)** — RSK-04 (Cybersecurity), RSK-05 (DPDPA), RSK-06 (Fraud & Mule Accounts), RSK-07 (Loan Default), RSK-08 (Soundbox Competition), RSK-09 (Talent Attrition), RSK-10 (Cash Burn), RSK-12 (Brand Erosion).
• **Moderate Severity (Score 6–10): 5 Risks (33.3%)** — RSK-11 (Litigation & SEBI), RSK-13 (Cloud Outage), RSK-14 (Macro Risk Weights), RSK-15 (CBDC Disruption).
• **Low Severity (Score 1–5): 0 Risks (0%)** — Reflects the elevated, high-scrutiny operating environment of an embattled systemic fintech.

4. Comprehensive Enterprise Risk Register (Part I: RSK-01 to RSK-08)

Detailed matrix detailing Risk ID, Description, Taxonomy, Risk Metrics (L, I, Score, Band), Risk Owners, and Mitigation Controls.

Risk ID & Title	Category & Description	L	I	Score	Risk Band	Mitigation Strategy & Action Plan	Key Risk Indicator (KRI)
RSK-01 Supervisory Action on Payments Bank (PPBL)	**[Regulatory & Compliance]** RBI directives under Section 35A of Banking Regulation Act 1949 prohibiting Paytm Payments Bank Ltd (PPBL) from accepting new deposits, credit transactions, or wallet top-ups due to persistent KYC/AML non-compliance.	5	5	**25**	Critical	Migrated nodal escrow accounts to major commercial banks (Axis Bank, HDFC Bank, SBI); transitioned UPI merchant handles to Third-Party Application Provider (TPAP) framework; separated corporate board governance from PPBL.	Zero outstanding regulatory show-cause notices; 100% daily transaction settlement stability across partner banks.
RSK-02 Disruption of Core Settlement & Escrow Operations	**[Operational & Continuity]** Severe disruption to merchant daily settlements and wallet balances arising from freezing of PPBL nodal accounts, risking merchant churn and liquidity gridlock.	4	5	**20**	Critical	Implemented multi-bank routing redundancy with automated fallback algorithms; distributed nodal settlement pools across multiple Tier-1 scheduled commercial banks.	Settlement success rate >= 99.95%; Average merchant settlement cycle < 4 hours.
RSK-03 UPI Market Share Cap & NPCI TPAP Dependency	**[Strategic & Market]** Risk of user transaction throttle if NPCI implements the 30% volume cap on third-party UPI apps; operational reliance on NPCI approval for multiple PSP partner bank handles.	4	4	**16**	High	Diversified multi-handle architecture (@ptaxis, @pthdfc, @ptsbi, @ptyes); accelerated monetization of non-UPI merchant devices (Soundbox, Card POS) and subscription SaaS.	Percentage of UPI volume managed via multi-bank TPAP architecture (target: 100%).
RSK-04 Cybersecurity Breaches & Infrastructure Outages	**[Cybersecurity & IT]** Advanced persistent threats (APT), ransomware, or cloud infrastructure outages compromising consumer financial records, transaction tokens, and core API gateways.	3	5	**15**	High	Zero-trust architecture, multi-factor hardware keys, PCI-DSS Level 1 compliance, quarterly external red-teaming, 24/7 Security Operations Center (SOC) with AI anomaly detection.	Mean Time to Detect (MTTD) < 5 mins; Mean Time to Respond (MTTR) < 15 mins; 0 critical CVE unpatched > 48h.
RSK-05 Digital Personal Data Protection Act (DPDPA) Non-Compliance	**[Legal & Privacy]** Potential financial penalties (up to INR 250 Cr per breach) and sanctions under DPDPA 2023 for improper consent artifacts, unauthorized cross-border telemetry, or data retention lapses.	3	4	**12**	High	Granular consent management platform (CMP), automated data lifecycle purge scripts, strict local data residency enforcement, periodic privacy impact assessments (PIA).	Consent artifact audit score 100%; Zero privacy regulatory notices.
RSK-06 Payment Fraud, Money Mules & Merchant Chargebacks	**[Operational & Fraud]** Exploitation of QR codes, merchant payment gateways, and peer-to-peer transfers by syndicated financial fraudsters, mule accounts, and phishing syndicates.	4	3	**12**	High	Real-time AI behavioral fraud scoring on transaction engines, biometric device binding, geo-velocity checks, instant freeze of suspicious merchant accounts.	Fraud-to-sales ratio < 0.015% of Gross Merchandise Value (GMV); Chargeback dispute win rate > 85%.
RSK-07 Credit Risk in Loan Distribution (BNPL & Postpaid)	**[Financial & Credit]** Elevated delinquency and non-performing loans in co-branded personal loans and merchant cash advances distributed via lending NBFC partners (e.g., Aditya Birla Capital, SMFG India).	3	4	**12**	High	Tighter underwriting filters: increased cut-off credit scores (bureau score > 720), reduced loan ticket sizes for unsecured Postpaid, enhanced collection tracking analytics.	Portfolio 90+ DPD (Days Past Due) < 1.8%; Lending partner delinquency loss rate.
RSK-08 Fierce Market Competition in Merchant Soundbox & QR	**[Strategic & Market]** Aggressive competitor subsidies and zero-rental Soundbox deployment by rivals (PhonePe, Google Pay, Pine Labs, BharatPe) causing merchant device churn.	4	3	**12**	High	Value-added merchant SaaS (inventory, billing, GST reconciliation, micro-insurance), proprietary Soundbox hardware with localized regional voice synthesis, long-term merchant tie-ins.	Monthly active merchant device churn rate < 1.2%; Net active subscription device additions.

4. Comprehensive Enterprise Risk Register (Part II: RSK-09 to RSK-15)

Continuation of risk register detailing human capital, liquidity, legal, infrastructure, macro, and technological displacement factors.

Risk ID & Title	Category & Description	L	I	Score	Risk Band	Mitigation Strategy & Action Plan	Key Risk Indicator (KRI)
RSK-09 Senior Leadership & Critical Talent Attrition	**[Human Capital]** Loss of key senior engineering, regulatory, and business leaders following public regulatory actions and depressed stock-option (ESOP) morale.	4	3	**12**	**High**	Restructured compensation packages with retention bonuses, revised ESOP strike prices, cross-functional succession planning for all Tier-1/Tier-2 leadership roles.	Key talent attrition rate < 8%; Key leadership position backup coverage ratio > 90%.
RSK-10 Prolonged Operating Cash Burn & Path-to-Profitability Risk	**[Financial & Liquidity]** Inability to sustain EBITDA before ESOP profitability due to revenue loss from PPBL wallet/payments, increased banking partner interchange fees, and marketing outlays.	3	4	**12**	**High**	Rigorous operational expense rationalization, AI-driven customer support automation, elimination of non-core ancillary ventures, dynamic pricing on merchant software.	EBITDA margin before ESOP > 5%; Cash runway reserves maintained > 24 months of opex.
RSK-11 Legal Litigation, SEBI Inquiries & Shareholder Lawsuits	**[Legal & Governance]** Inquiries from SEBI, Enforcement Directorate (ED), and shareholder litigation concerning past founder ESOP allotments, disclosure timing, and compliance attestations.	3	3	**9**	**Moderate**	Established Independent Board Oversight Committee; engaged top-tier forensic audit firms; formalized timely disclosures per SEBI LODR Regulations.	100% adherence to disclosure statutory timelines; zero unresolved legal summons.
RSK-12 Brand Equity Erosion & Consumer Trust Deficit	**[Strategic & Reputational]** Negative media narratives, viral social media misinformation regarding wallet safety, and brand perception decline leading to consumer inactivity.	3	4	**12**	**High**	Proactive multi-channel consumer transparency campaigns ('Paytm Karo, Aaj Bhi aur Kal Bhi'); dedicated 24/7 user grievance resolution cell.	Net Promoter Score (NPS) >= +55; Brand sentiment positivity index > 75%.
RSK-13 Third-Party Cloud Provider & Telco Outage Dependency	**[Operational & Technology]** Single-point-of-failure risks in cloud service providers (AWS/Azure) or domestic telecom SMS/telemetry pipelines causing transient payment processing delays.	2	4	**8**	**Moderate**	Multi-region hybrid cloud deployment; dynamic routing across major telecom operators (Airtel, Jio, Vi) for SMS OTP delivery and IoT Soundbox SIM telemetry.	Core platform availability uptime >= 99.99%; SMS OTP delivery latency < 3 seconds.
RSK-14 Macroeconomic Tightening & RBI Risk Weight Hikes	**[Financial & Macro]** RBI policy circular raising capital risk weights on unsecured consumer loans and bank-NBFC funding by 2500 bps, raising partner borrowing costs and crimping loan disbursal margins.	3	3	**9**	**Moderate**	Shifted loan origination focus toward secured MSME collateralized loans and merchant supply-chain credit; broadened partner base to include public-sector banks.	Secured vs unsecured loan distribution ratio; Average loan partner cost-of-capital spread.
RSK-15 CBDC (e-Rupee) & ONDC Disruptive Disintermediation	**[Strategic & Technological]** Long-term technological disintermediation of fintech wallets and payment aggregator gateways by the RBI Retail Digital Rupee (CBDC-R) and government ONDC commerce network.	2	3	**6**	**Moderate**	Integrated CBDC wallet interoperability directly within the Paytm app; launched dedicated buyer and merchant logistics apps on the ONDC protocol.	Active registered CBDC & ONDC user base; GMV routed through open networks.

Risk Governance & Allocation of Accountability

Effective risk response requires clear institutional governance. At One97 Communications, ownership of the Risk Register is vested in the **Risk Management Committee of the Board (RMC)**, chaired by an Independent Director. Day-to-day enforcement is governed by the **Three Lines of Defense** model: (1) First Line: Business Unit Heads responsible for front-line compliance and fraud screening; (2) Second Line: Chief Risk Officer (CRO) and Chief Compliance Officer (CCO) defining policies and stress-testing thresholds; and (3) Third Line: Internal Audit Department providing independent assurance directly to the Board Audit Committee.

5. Risk Mitigation & Resilience Implementation Roadmap

To insulate Paytm against existential regulatory headwinds and rebuild market trust, a phased, four-pillar risk management framework is established across short-, medium-, and long-term horizons:

Pillar / Strategic Horizon	Core Focus & Target Risks	Architectural Interventions & Deliverables	Success Milestone
Pillar 1: Structural Decoupling & Banking Redundancy ***Horizon: Immediate (0-3 Months)***	RSK-01 (PPBL Regulatory Action) RSK-02 (Settlement Disruption) RSK-03 (UPI TPAP Migration)	• Complete migration of all merchant QR virtual payment addresses (VPAs) to major commercial banks. • Secure Multi-Bank TPAP handles with Axis Bank, HDFC Bank, SBI, and YES Bank. • Ring-fence Paytm parent balance sheet completely from PPBL.	Zero merchant transaction disruption; 100% active VPA re-anchoring.
Pillar 2: Zero-Trust Security & AML Fortification ***Horizon: Short-Term (3-6 Months)***	RSK-04 (Cybersecurity) RSK-05 (DPDPA 2023) RSK-06 (Fraud & Mule Accounts)	• Implement graph-database AML transaction network analysis to detect syndicated mule networks. • Deploy quantum-resilient encryption across customer biometric and tokenized card vaults. • Establish automated consent-revocation architecture under DPDPA guidelines.	Zero regulatory penalties; Fraud rate maintained < 0.012% GMV.
Pillar 3: High-Margin Product Pivot & Credit Tightening ***Horizon: Medium-Term (6-12 Months)***	RSK-07 (Lending Delinquency) RSK-08 (Soundbox Competition) RSK-10 (Operating Cash Burn)	• De-emphasize sub-prime Postpaid BNPL loans in favor of secured merchant enterprise loans. • Upgrade Soundbox devices to 4G IoT Linux terminals with integrated card-tap POS. • Rationalize non-performing operational subsidiaries and optimize cloud computing spend.	Sustainable positive EBITDA; Net monthly active Soundbox additions > 150k.
Pillar 4: Institutional Governance & Brand Restoration ***Horizon: Long-Term (12-24 Months)***	RSK-09 (Talent Retention) RSK-11 (Litigation & SEBI) RSK-12 (Brand Equity Loss)	• Expand Independent Board seats with retired central bankers and regulatory compliance experts. • Overhaul employee stock ownership plans (ESOPs) with performance-linked vesting hurdles. • Launch national merchant trust & investor relations transparency campaign.	NPS > +60; Long-term credit rating upgrade to AA+.

6. Audit & Supervisory Attestation

Attestation Statement: This Risk Mitigation and Management Plan has been developed in conformance with ISO 31000:2018 Risk Management Principles and the Committee of Sponsoring Organizations of the Treadway Commission (COSO) Enterprise Risk Management Framework. The identified 15 risk exposures and corresponding KRI thresholds represent the verified risk baseline extracted from One97 Communications Limited statutory disclosures, audited financial notes, and regulatory enforcement filings.

Prepared By:
Student Analyst / Risk Engineering Group
B.Tech CSE (BDA & DS)

Reviewed By:
Chief Risk Officer (CRO) / Internal Audit
One97 Communications Ltd

Faculty In-Charge:
Dr. V. Prasanna
Dept of DSBS, SRMIST